

PROJECT 1 – THREAT MODEL THE AI IDENTITY SYSTEM

Introduction:

This project focuses on security threat modeling for an AI-based identity security system. The system includes user authentication, an AI agent, internal APIs, an LLM, and a RAG knowledge base. Since these components handle authentication information and sensitive data, they may be exposed to different security attacks.

The project studies the system flow and identifies possible threats that could affect different components. It focuses on attacks such as identity token theft, authentication tampering, LLM API key exposure, agent identity spoofing, and RAG knowledge-base poisoning.

The identified threats are further analyzed using attack trees and the STRIDE model. A risk register is used to evaluate the likelihood and impact of each threat and to assign suitable security controls. The threats are also mapped to MITRE ATLAS techniques to understand the related AI attack methods.

The overall aim is to understand the possible security weaknesses in the system and provide a clear approach for identifying, analyzing, prioritizing, and controlling security risks.

Step 1 – Secure Nova AI Identity Data Flow

Description:

The data flow represents the main components of the Secure Nova AI Identity Security system and how they communicate with each other. A human user sends a request through the identity provider, which connects to the application and AI agent. The AI agent communicates with the internal APIs, LLM, and RAG knowledge base. The arrows represent the flow of requests and responses between these components.

Threat Dragon v2.6.2-latest English

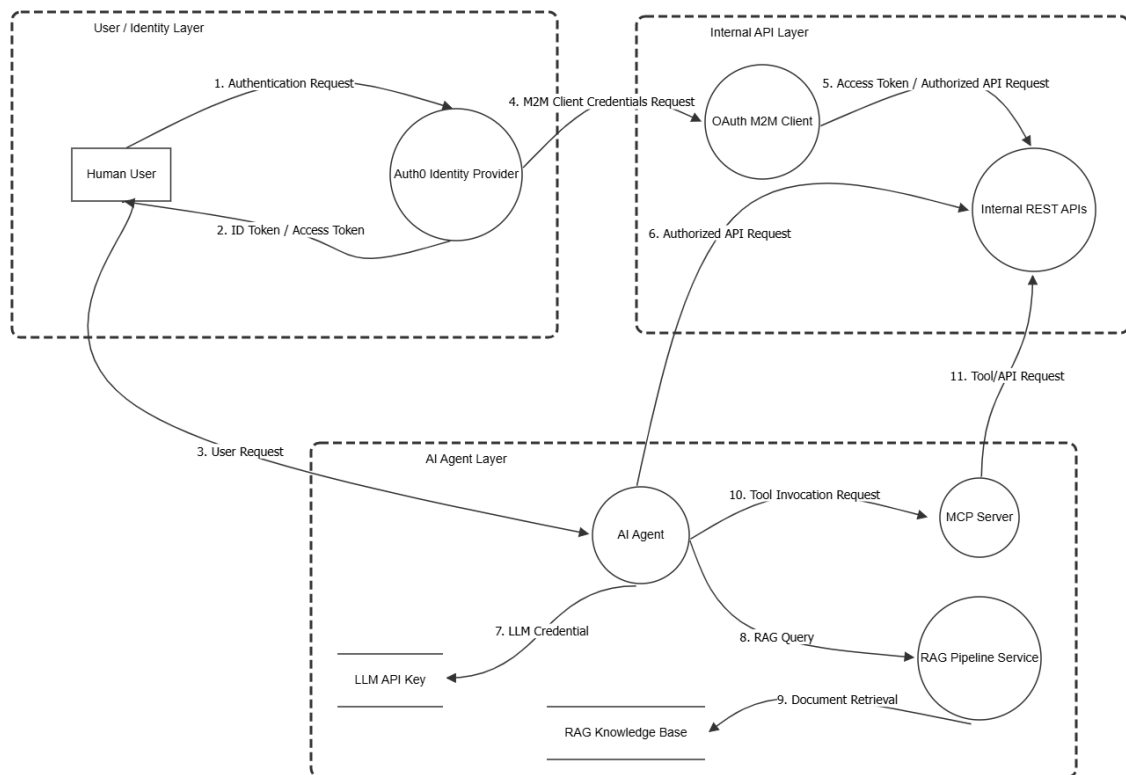
SecureNova AI Identity Data Flow

The diagram illustrates the data flow for SecureNova AI Identity. It is divided into three main layers:

- User / Identity Layer:** Contains a Human User and an Auth0 Identity Provider. The flow starts with an Authentication Request (1) from the user to the provider, followed by an ID Token / Access Token (2) being sent back to the user.
- Internal API Layer:** Contains an OAuth M2M Client and Internal REST APIs. The Auth0 Identity Provider sends an M2M Client Credentials Request (4) to the OAuth M2M Client, which then sends an Access Token / Authorized API Request (5) to the Internal REST APIs. The Internal REST APIs send an Authorized API Request (6) back to the OAuth M2M Client.
- AI Agent Layer:** Contains an AI Agent, an LLM API Key, an LLM Credential, a RAG Knowledge Base, a RAG Pipeline Service, and an MCP Server. The Human User sends a User Request (3) to the AI Agent. The AI Agent sends an LLM Credential (7) to the LLM API Key and a RAG Query (8) to the RAG Pipeline Service. The RAG Pipeline Service performs Document Retrieval (9) from the RAG Knowledge Base and sends a Tool/API Request (11) to the MCP Server. The MCP Server sends a Tool Invocation Request (10) back to the AI Agent.

Properties: Select an element on the graph to edit

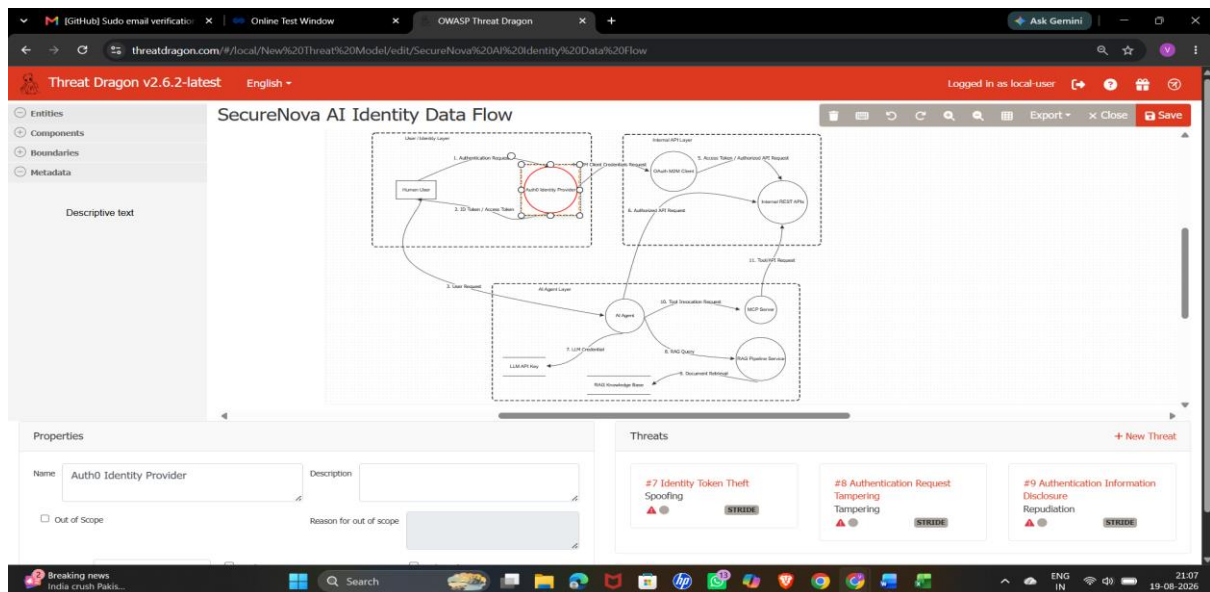
Threats: Select an element on the graph to add a threat



Step 2 – Authentication Threats

Description:

The Auth0 identity provider is selected, and the related security threats are identified. The threats include identity token theft, authentication request tampering, and authentication information disclosure. These threats represent possible security risks in the authentication process.



Step 3 – LLM API Key Exfiltration Attack Tree

Description:

The attack tree explains different ways an attacker could obtain the LLM API key through prompt injection. The possible paths include malicious user prompts, indirect prompt injection, and poisoned RAG content. These attacks may cause sensitive information to be revealed and could lead to API key exposure.

Untitled Diagram - draw.io

Ask Gemini

app.diagrams.net/?utm_source=chatgpt.com

Untitled Diagram

File Edit View Arrange Extras Help

Unsaved changes. Click here to save.

Share

55%

Type / to search

Scratchpad

General

More Shapes

Diagram

Style

View

Options

Paper Size

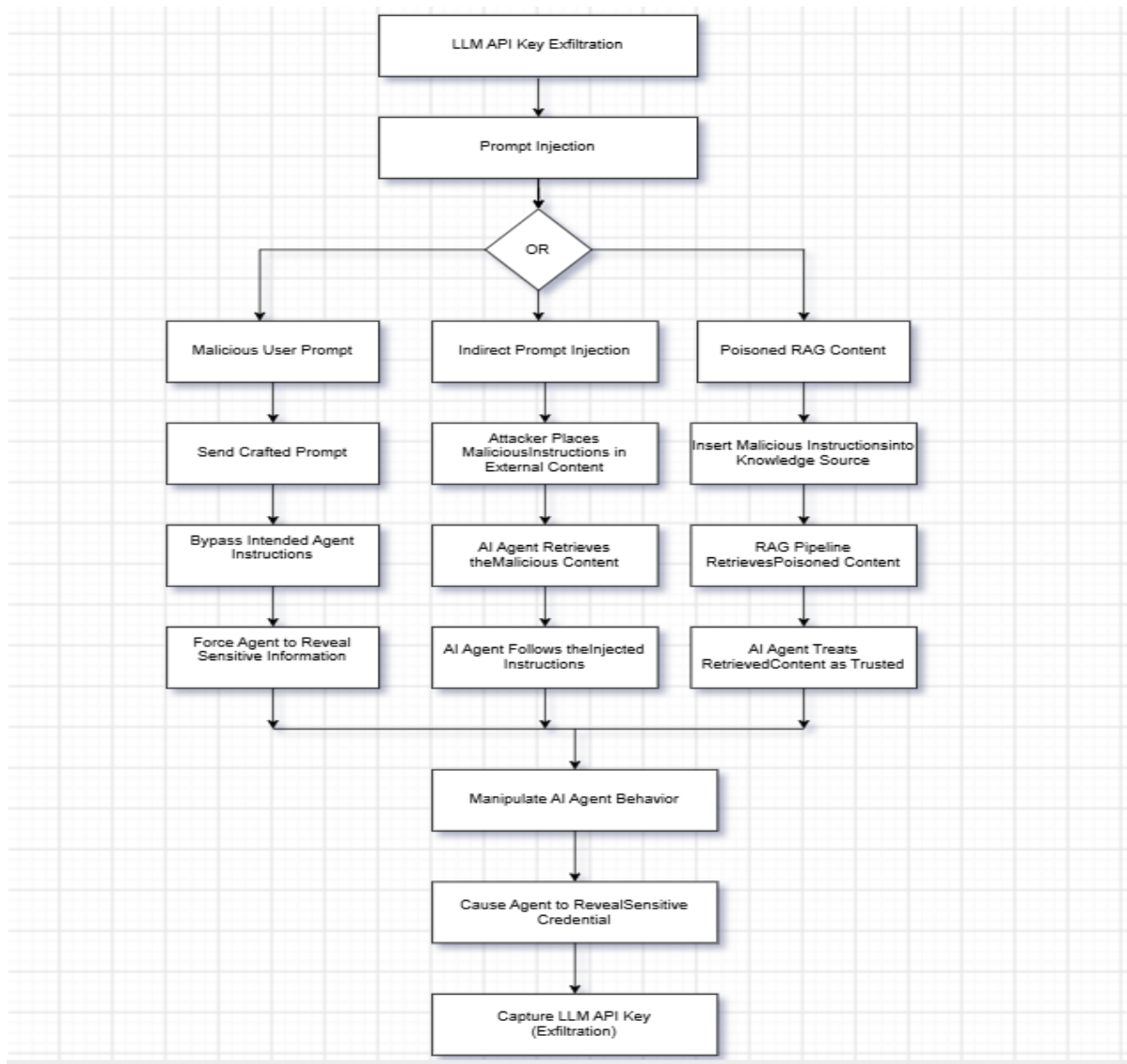
30°C

Partly cloudy

Search

22:39

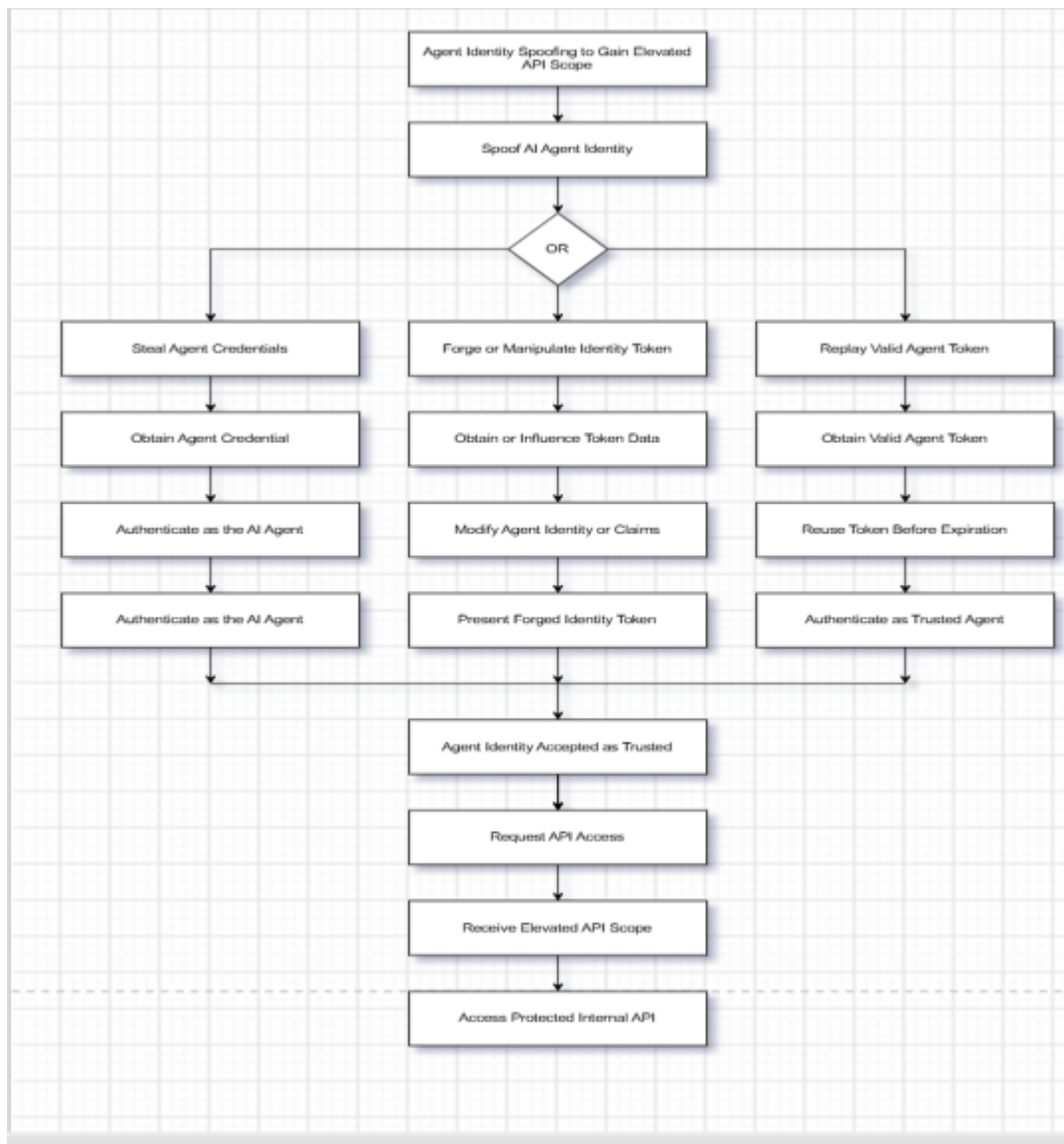
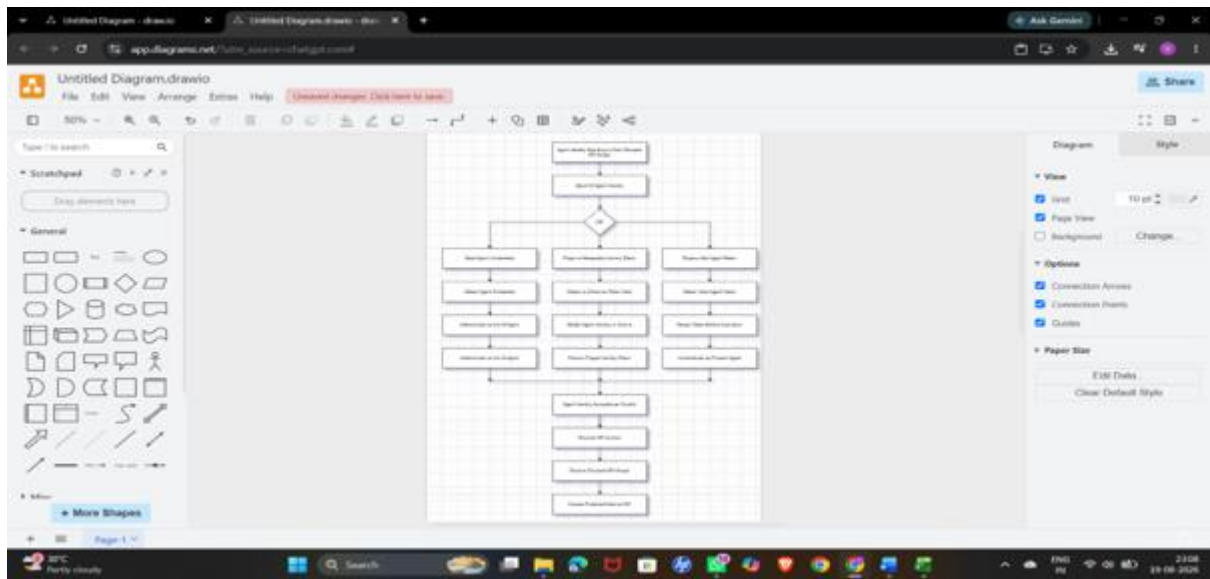
19-08-2026



Step 4 – Agent Identity Spoofing Attack Tree

Description:

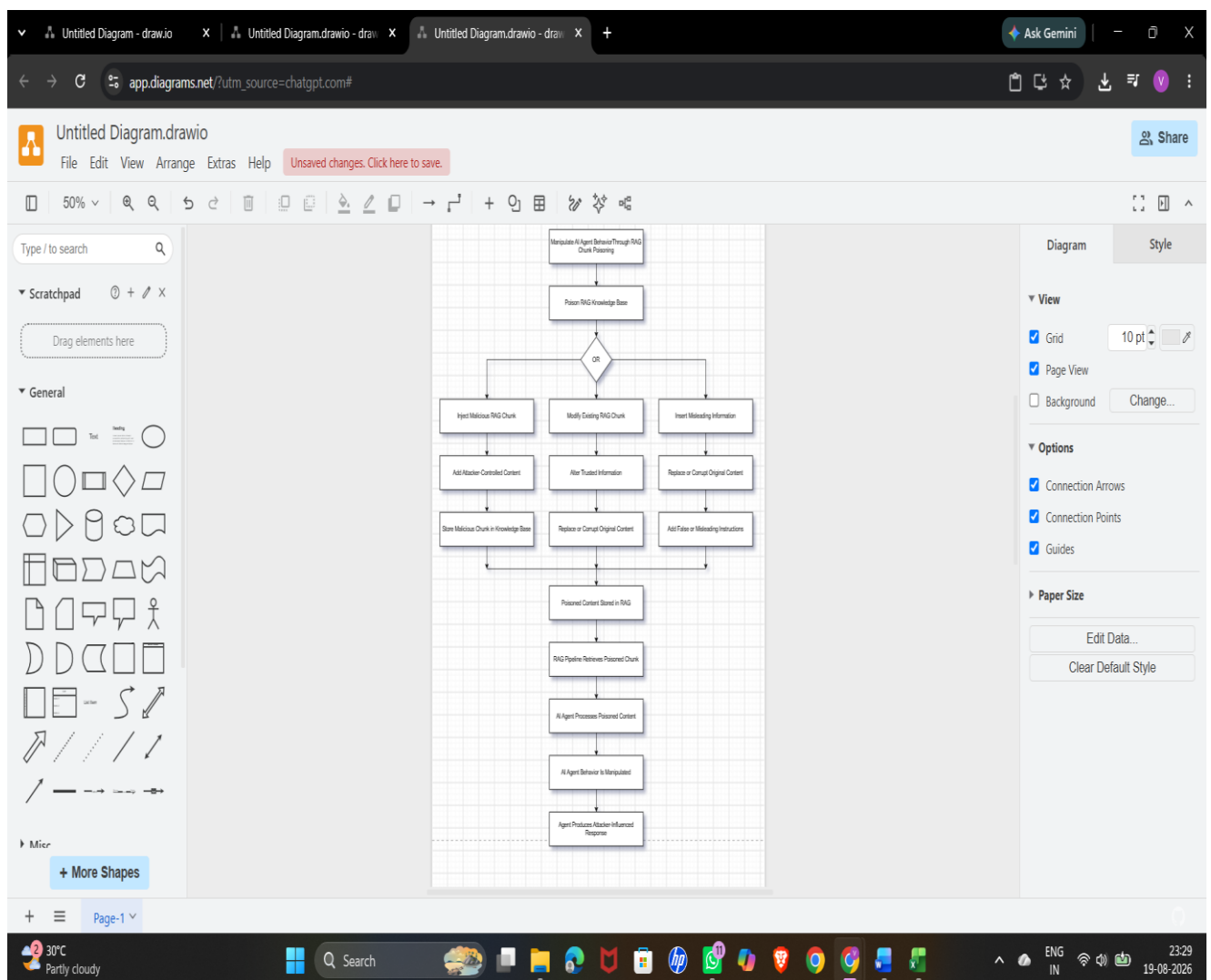
The attack tree explains different ways an attacker could pretend to be a trusted AI agent. Possible methods include stealing agent credentials, modifying or forging an identity token, and replaying a valid token. Successful exploitation may provide access to protected internal APIs with higher privileges.

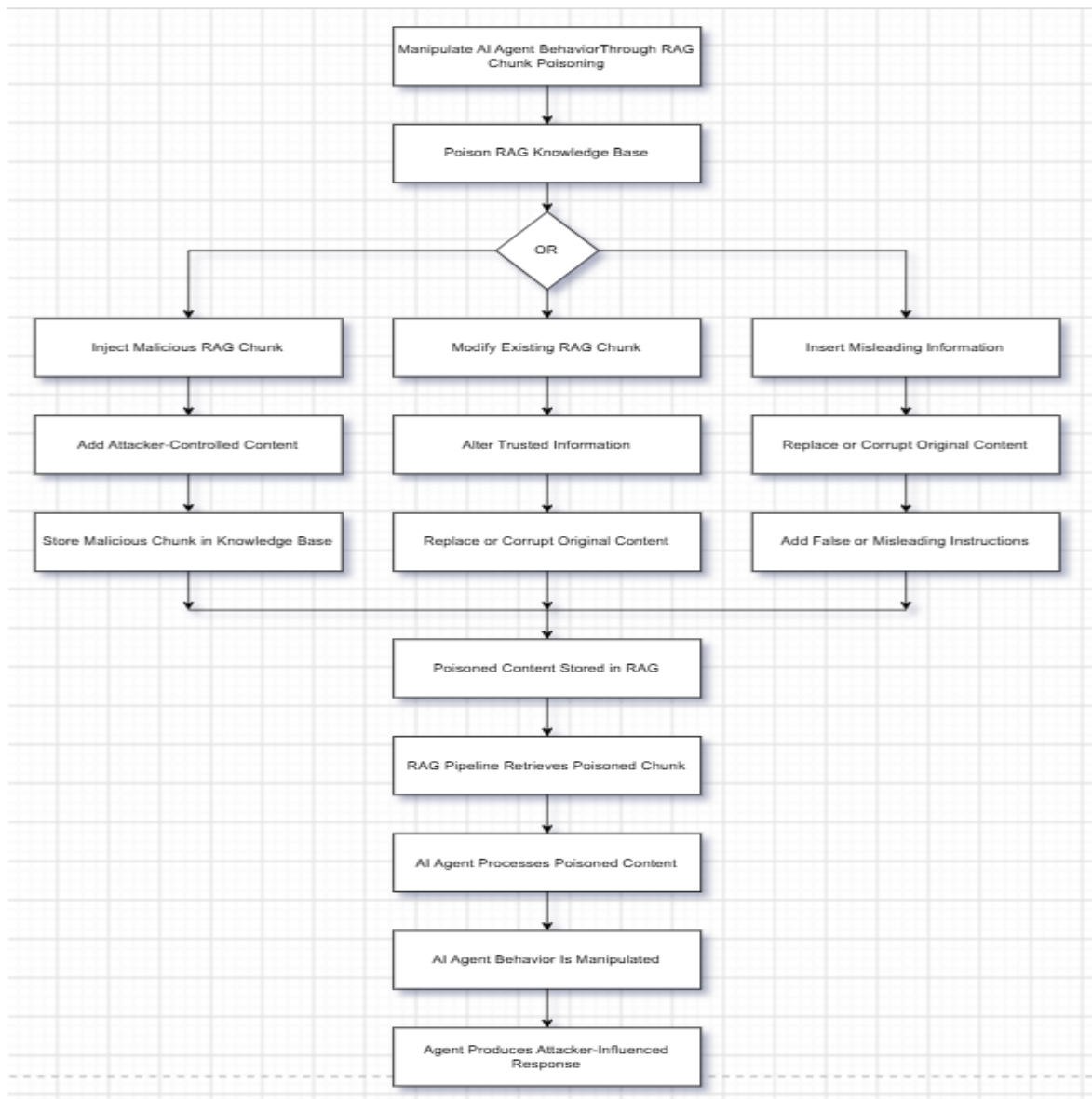


Step 5 – RAG Chunk Poisoning Attack Tree

Description:

The attack tree explains how an attacker could add, modify, or insert misleading information into the RAG knowledge base. The poisoned information can later be retrieved by the RAG pipeline and processed by the AI agent. This may cause the AI agent to generate an incorrect or attacker-influenced response.





Step 6 – STRIDE Threat Matrix

Description:

The threat matrix organizes the identified security threats using the six STRIDE categories: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege. The system components are matched with the possible threats that may affect them.

B22							
	A	B	C	D	E	F	G
1	Component	Spoofing	Tampering	Repudiation	Information Disclosure	Denial of Service	Elevation of Privilege
2	Human User	Identity Spoofing	Unauthorized Modification	User Denies Action	Credential Exposure	Account Abuse	Unauthorized Privilege
3	Auth0 Identity Provider	Identity Spoofing	Token/Claim Manipulation	Authentication Activity Dispute	Token Disclosure	Authentication Disruption	Privilege Escalation
4	AI Agent	Agent Identity Spoofing	Prompt/RAG Manipulation	Untraceable Agent Action	LLM API Key Disclosure	Prompt/Resource Exhaustion	Unauthorized API Access
5	Internal REST APIs	Agent Identity Spoofing	API Request Manipulation	Untracked API Request	Unauthorized Data Access	API Flooding	Elevated API Scope
6	RAG Knowledge Base	-	RAG Chunk Poisoning	Untracked Content Modification	Sensitive Document Exposure	RAG Resource Exhaustion	Unauthorized Knowledge Modification
7	MCP Server	Tool Identity Spoofing	Tool/API Request Manipulation	Untracked Tool Invocation	Sensitive Tool Data Exposure	Tool Abuse	Unauthorized Tool Access
8	External LLM Provider	Provider/API Identity Spoofing	Prompt Manipulation	Untracked LLM Request	Credential Disclosure	Excessive Requests	Unauthorized Capability Use
9							
10							

AutoSave Off STRIDE Matrix

File Home Insert Draw Page Layout Formulas Data Review View Help

Clipboard Font Alignment Number Styles Cells Editing Add-ins

Component	Spoofing	Tampering	Repudiation	Information Disclosure	Denial of Service	Elevation of Privilege
Human User	Identity Spoofing	Unauthorized Modification	User Denies Action	Credential Exposure	Account Abuse	Unauthorized Privilege
AuthN Identity Provider	Identity Spoofing	Token/Claim Manipulation	Authentication Activity Dispute	Token Disclosure	Authentication Disruption	Privilege Escalation
AI Agent	Agent Identity Spoofing	Prompt/RAG Manipulation	Untraceable Agent Action	LLM API Key Disclosure	Prompt/Resource Exhaustion	Unauthorized API Access
Internal REST APIs	Agent Identity Spoofing	API Request Manipulation	Untracked API Request	Unauthorized Data Access	API Flooding	Elevated API Scope
RAG Knowledge Base	-	RAG Chunk Poisoning	Untracked Content Modification	Sensitive Document Exposure	RAG Resource Exhaustion	Unauthorized Knowledge Modification
MCP Server	Tool Identity Spoofing	Tool/API Request Manipulation	Untracked Tool Invocation	Sensitive Tool Data Exposure	Tool Abuse	Unauthorized Tool Access
External LLM Provider	Provider/API Identity Spoofing	Prompt Manipulation	Untracked LLM Request	Credential Disclosure	Excessive Requests	Unauthorized Capability Use

Sheet1

Ready Accessibility: Good to go

28°C Partly cloudy

Search

ENG IN 00:12 20-08-2026

Step 7 – Risk Register

Description:

The risk register contains the identified security threats along with their likelihood, impact, risk score, and priority. It also includes the responsible owner and the security control planned for each risk. This helps in identifying the risks that require higher attention.

AutoSave Off Risk Register - Saved to this PC

File Home Insert Draw Page Layout Formulas Data Review View Help

Clipboard Font Alignment Number Styles Cells Editing Add-ins

ID	Threat	Source / Component	STRIDE Category	Likelihood	Impact	Risk Score	Risk Rank	Owner	Mitigation / Control	Status
T01	LLM API key exfiltration via prompt injection	AI Agent / LLM	Information Disclosure	4	5	20	Critical	AI Security Engineer	Prompt injection guardrails and JWT output scanning	Open
T02	Agent identity spoofing	AI Agent	Spoofing	4	5	20	Critical	IAM Security Engineer	Cryptographic agent identity binding and re-verification	Open
T10	Agent privilege escalation through prompt injection	AI Agent / Internal API	Elevation of Privilege	4	5	20	Critical	AI Security Engineer	Prompt injection guardrails and least-privilege authorization	Open
T03	RAG chunk poisoning	RAG Pipeline / Knowledge Base	Tampering	4	4	16	High	AI Security Engineer	RAG content validation and poisoning detection	Open
T08	Credential exposure through agent context	AI Agent	Information Disclosure	4	4	16	High	AI Security Engineer	Sensitive credential redaction	Open
T05	Unauthorized API scope	Internal REST APIs	Elevation of Privilege	3	5	15	Medium	API Security Engineer	Least privilege and API scope enforcement	Open
T06	Compromised OAuth M2M client	OAuth M2M Client	Spoofing	3	5	15	Medium	IAM Security Engineer	Short-lived M2M credentials and credential rotation	Open
T04	System prompt extraction	AI Agent	Information Disclosure	3	4	12	Medium	AI Security Engineer	System prompt protection and output filtering	Open
T07	Unauthorized MCP tool invocation	MCP Server	Elevation of Privilege	3	4	12	Medium	AI Platform Security Engineer	MCP tool authorization and agent identity verification	Open
T09	Unauthorized modification of RAG knowledge	RAG Pipeline	Tampering	3	4	12	Medium	RAG Platform Owner	RAG integrity controls and trusted-source validation	Open

Likelihood × Impact = Risk Score

Sheet1

Ready Accessibility: Investigate

29°C Partly cloudy

Search

ENG IN 00:39 20-08-2026

	A	B	C	D	E	F	G	H	I	J	K
1	ID	Threat	Source / Component	STRIDE Category	Likelihood	Impact	Risk Score	Risk Rank	Owner	Mitigation / Control	Status
2	T01	LLM API key exfiltration via prompt injection	AI Agent / LLM	Information Disclosure	4	5	20	Critical	AI Security Engineer	Prompt injection guardrails and JWT output scanning	Open
3	T02	Agent identity spoofing	AI Agent	Spoofing	4	5	20	Critical	IAM Security Engineer	Cryptographic agent identity binding and re-verification	Open
4	T10	Agent privilege escalation through prompt injection	AI Agent / Internal API	Elevation of Privilege	4	5	20	Critical	AI Security Engineer	Prompt injection guardrails and least-privilege authorization	Open
5	T03	RAG chunk poisoning	RAG Pipeline / Knowledge Base	Tampering	4	4	16	High	AI Security Engineer	RAG content validation and poisoning detection	Open
6	T08	Credential exposure through agent context	AI Agent	Information Disclosure	4	4	16	High	AI Security Engineer	Sensitive credential redaction	Open
7	T05	Unauthorized API scope	Internal REST APIs	Elevation of Privilege	3	5	15	Medium	API Security Engineer	Least privilege and API scope enforcement	Open
8	T06	Compromised OAuth M2M client	OAuth M2M Client	Spoofing	3	5	15	Medium	IAM Security Engineer	Short-lived M2M credentials and credential rotation	Open
9	T04	System prompt extraction	AI Agent	Information Disclosure	3	4	12	Medium	AI Security Engineer	System prompt protection and output filtering	Open
10	T07	Unauthorized MCP tool invocation	MCP Server	Elevation of Privilege	3	4	12	Medium	AI Platform Security Engineer	MCP tool authorization and agent identity verification	Open
11	T09	Unauthorized modification of RAG knowledge	RAG Pipeline	Tampering	3	4	12	Medium	RAG Platform Owner	RAG integrity controls and trusted-source validation	Open
12											
13											
14											
15											
16											

Likelihood × Impact = Risk Score

Step 8 – MITRE ATLAS Threat Mapping

Description:

The identified security threats are mapped to related MITRE ATLAS techniques. The mapping connects each threat with a relevant AI attack technique and provides information about how the technique relates to the identified risk. This helps in understanding the threats using recognized AI security techniques.

MITRE ATLAS • Saved to this PC			
File Home Insert Draw Page Layout Formulas Data Review View Help			
D4 An attacker poisons or manipulates retrieved knowledge so that the AI agent processes malicious or misleading information and produces attacker-influenced behavior.			
Threat	MITRE ATLAS Technique ID	Technique Name	Relevance to SecureNova
LLM API Key Exfiltration via Prompt Injection	AML T0051	LLM Prompt Injection	An attacker uses malicious prompts to influence the AI agent and attempt to cause disclosure of the LLM API key.
Agent Identity Spoofing	AML T0073	Impersonation	An attacker attempts to impersonate a trusted AI agent identity in order to obtain unauthorized access or capabilities.
RAG Chunk Poisoning	AML T0070	RAG Poisoning	An attacker poisons or manipulates retrieved knowledge so that the AI agent processes malicious or misleading information and produces attacker-influenced

D4 An attacker poisons or manipulates retrieved knowledge so that the AI agent processes malicious or misleading information and produces attacker-influenced behavior.			
Threat	MITRE ATLAS Technique ID	Technique Name	Relevance to SecureNova
LLM API Key Exfiltration via Prompt Injection	AML T0051	LLM Prompt Injection	An attacker uses malicious prompts to influence the AI agent and attempt to cause disclosure of the LLM API key.
Agent Identity Spoofing	AML T0073	Impersonation	An attacker attempts to impersonate a trusted AI agent identity in order to obtain unauthorized access or capabilities.
RAG Chunk Poisoning	AML T0070	RAG Poisoning	An attacker poisons or manipulates retrieved knowledge so that the AI agent processes malicious or misleading information and produces attacker-influenced

MITRE ATLAS™

MatrixTacticsTechniquesMitigationsCase StudiesToolsResourcesContribute

Techniques

ATLAS-matrix

- Reconnaissance
- Resource Development
- Initial Access
- AI Model Access
- Execution
- Persistence
 - AI Agent Context Poisoning
 - Memory
 - Thread
 - AI Agent Tool Data Poisoning
 - AI Agent Tool Poisoning
 - Definition and Instructions
 - Implementation

Home > Techniques > RAG Poisoning

RAG Poisoning

Adversaries may inject malicious content into data indexed by a retrieval augmented generation (RAG) system to contaminate a future thread through RAG-based search results. This may be accomplished by placing manipulated documents in a location the RAG indexes (see [Gather RAG-Indexed Targets](#)).

The content may be targeted such that it would always surface as a search result for a specific user query. The adversary's content may include false or misleading information. It may also include prompt injections with malicious instructions, or false RAG entries.

ID: AML.T0070

Tactics: Persistence

Maturity: Demonstrated

Platforms: Agentic AI, Generative AI

Number of Case Studies: 3

Number of Mitigations: 2

Created: 12 March 2025

Last Modified: 27 May 2026

Version Permalink (v2026.07)

Procedure Examples

ID	Name	Actor	Tactic	Description
----	------	-------	--------	-------------

33°C Mostly cloudy

Search

ENG IN 12:48 20-08-2026

MITRE ATLAS™

MatrixTacticsTechniquesMitigationsCase StudiesToolsResourcesContribute

Techniques

ATLAS-matrix

- Reconnaissance
- Resource Development
- Initial Access
- AI Model Access
- Execution
- Persistence
- Privilege Escalation
- Defense Evasion
 - AI Supply Chain Reputation Inflation
 - AI Supply Chain Rug Pull
 - Corrupt AI Model
 - Delay Execution of LLM Instructions
 - Evade AI Model

Home > Techniques > Impersonation

Impersonation

Adversaries may impersonate a trusted person or organization in order to persuade and trick a target into performing some action on their behalf. For example, adversaries may communicate with victims (via [Phishing](#), or [Spearphishing via Social Engineering LLM](#)) while impersonating a known sender such as an executive, colleague, or third-party vendor. Established trust can then be leveraged to accomplish an adversary's ultimate goals, possibly against multiple victims.

Adversaries may target resources that are part of the AI DevOps lifecycle, such as model repositories, container registries, and software registries.

ID: AML.T0073

ATT&CK Reference: T1656

Tactics: Defense Evasion

Maturity: Realized

Platforms: Enterprise

Number of Case Studies: 5

Number of Mitigations: 0

Created: 14 April 2025

Last Modified: 27 May 2026

Version Permalink (v2026.07)

Procedure Examples

ID	Name	Actor	Tactic	Description
----	------	-------	--------	-------------

Nifty midcap +0.7%

Search

ENG IN 12:48 20-08-2026

MITRE ATLAS™

MatrixTacticsTechniquesMitigationsCase StudiesToolsResourcesContribute

Techniques

ATLAS-matrix

- Reconnaissance
- Resource Development
- Initial Access
- AI Model Access
- Execution
 - AI Agent Clickbait
 - AI Agent Tool Invocation
 - Command and Scripting Interpreter
 - Deploy AI Agent
 - LLM Prompt Injection
 - Direct
 - Indirect
 - Triggered

Home > Techniques > LLM Prompt Injection

Subtechniques

LLM Prompt Injection

An adversary may craft malicious prompts as inputs to an LLM that cause the LLM to act in unintended ways. These "prompt injections" are often designed to cause the model to ignore aspects of its original instructions and follow the adversary's instructions instead.

Prompt injections can be an initial access vector to the LLM that provides the adversary with a foothold to carry out other steps in their operation. They may be designed to bypass defenses in the LLM, or allow the adversary to issue privileged commands. The effects of a prompt injection can persist throughout an interactive session with an LLM.

Malicious prompts may be injected directly by the adversary ([Direct](#)) either to leverage the LLM to generate harmful content or to gain a foothold on the system and lead to further effects. Prompts may also be injected indirectly when the LLM, as part of its normal operation, ingests the malicious prompt from another data source ([Indirect](#)). This type of injection can be used by the adversary to gain a foothold on the system or to target the user of the LLM. Malicious prompts may also be [Triggered](#) by user actions or system events.

ID: AML.T0051

Tactics: Execution

Maturity: Realized

Platforms: Agentic AI, Generative AI

Number of Case Studies: 1

Number of Mitigations: 7

Created: 25 October 2023

Last Modified: 27 May 2026

Version Permalink (v2026.07)

Procedure Examples

ID	Name	Actor	Tactic	Description
----	------	-------	--------	-------------

Nifty midcap +0.79%

Search

ENG IN 12:50 20-08-2026

